

Audits de sécurité & conformité ISO 27001 — FDJ

Participation aux audits SSI du groupe cybersécurité de la Française des Jeux : préparation, suivi des vulnérabilités, priorisation CVSS et reporting de conformité.

ENTREPRISE

FDJ · Boulogne-
Billancourt

CADRE

Stage BTS SIO

ÉQUIPE

Groupe cybersécurité
(audit SSI)

RÉFÉRENTIEL

ISO/IEC 27001

01 Contexte

La Française des Jeux (FDJ), premier opérateur de jeux d'argent en France, est soumise à une réglementation stricte (ANJ, RGPD) et fait l'objet d'audits de sécurité réguliers, internes et externes. Son groupe cybersécurité s'appuie sur des équipes d'audit, une Red Team interne et une plateforme de bug bounty (Yogosha) pour détecter les vulnérabilités de manière proactive.

Pendant mon stage, j'ai été intégré à la cellule d'audit SSI. Mon rôle : contribuer à la préparation et au suivi des audits, suivre le cycle de vie des vulnérabilités et produire les éléments de reporting destinés au RSSI.

CONFIDENTIALITÉ

Cette fiche décrit la méthode et les outils. Aucun résultat d'audit, périmètre sensible ou vulnérabilité réelle de l'entreprise n'y est divulgué.

02 Missions réalisées

Mission	Ce que j'ai fait
Suivi d'audits	Suivi de campagnes d'audit (exercice Red Team 2024-2025, périmètres Middle et Back Office) : collecte des éléments, suivi des actions, relances des équipes.
Ciblage des audits	Identification des équipements prioritaires à auditer selon leur exposition et leur criticité métier.
Tests d'intrusion physique	Participation, sous encadrement, à des tests d'intrusion physique sur les sites de Vitrolles et de Boulogne.
Gestion des vulnérabilités	Analyse des rapports publiés sur Yogosha, qualification et suivi jusqu'à la correction.
Gestion d'incidents	Prise en charge et suivi d'incidents techniques avec les équipes concernées.
Reporting	Rédaction de rapports techniques et de synthèses SharePoint / Power BI pour le suivi de conformité ISO 27001.

03 Méthodologie d'audit suivie

- 1 **Cadrage** : périmètre, objectifs, interlocuteurs, règles d'engagement et calendrier.
- 2 **Collecte** : inventaire des actifs, schémas de flux, configurations, entretiens avec les équipes.
- 3 **Analyse** : contrôles techniques (flux réseau, interfaces d'administration, correctifs) et organisationnels, comparés aux exigences de l'annexe A d'ISO 27001.

- 4 **Qualification** : chaque constat reçoit un score CVSS et un niveau de priorité.
- 5 **Restitution** : rapport, plan de remédiation priorisé et présentation adaptée au public (technique ou métier).
- 6 **Suivi** : contrôle de la mise en œuvre des corrections et clôture des constats.

04 Cycle de vie d'une vulnérabilité (Yogosha)

Étape	Action	Livrable
Réception	Lecture du rapport du chercheur, reproduction si possible	Rapport qualifié
Triage	Vérification du périmètre, dédoublonnage, score CVSS	Niveau de sévérité
Affectation	Transmission à l'équipe propriétaire de l'actif	Ticket de correction
Correction	Suivi de la remédiation et des délais	Correctif déployé
Vérification	Nouveau test pour confirmer la correction	Clôture documentée

05 Priorisation CVSS

Score CVSS v3.1	Sévérité	Délai de traitement visé
9,0 – 10,0	Critique	Immédiat, mesure de contournement si nécessaire
7,0 – 8,9	Élevée	Court terme
4,0 – 6,9	Moyenne	Planifiée dans le cycle de correctifs
0,1 – 3,9	Faible	Traitée lors d'une prochaine évolution

Le score est complété par le contexte métier : exposition Internet, sensibilité des données, existence d'un exploit public.

06 Reporting et conformité ISO 27001

- Tableaux de bord **Power BI** pour le comité RSSI : répartition des constats par sévérité et par périmètre, avancement des plans d'action.
- Espace **SharePoint** centralisant rapports, preuves et suivi des actions, partagé avec les équipes via **Teams**.
- Vulgarisation des risques auprès des équipes non techniques : impact métier, recommandation, priorité.

07 Outils

Yogosha (bug bounty)	IBM QRadar (SIEM)	Wazuh	Nexus	Power BI	SharePoint	Microsoft Teams	CVSS v3.1
ISO/IEC 27001							

08 Résultats

5 audits de sécurité suivis	15+ rapports et synthèses rédigés	20+ risques qualifiés et priorisés	10+ plans de remédiation proposés
--------------------------------	--------------------------------------	---------------------------------------	--------------------------------------

09 Difficultés et solutions

Difficulté	Solution
Prise en main d'outils professionnels complexes (QRadar, Wazuh, Nexus, Yogosha) et des notions d'audit technique	Formations internes, sessions en binôme avec l'équipe et temps dédié à chaque plateforme
Plusieurs audits en parallèle sur différents sites (Boulogne, Vitrolles, Marseille), parfois à distance	Planning personnel avec suivi quotidien, usage structuré de Teams et SharePoint, points réguliers pour réajuster les priorités

10 Compétences mobilisées

- Analyse et qualification de vulnérabilités, lecture de rapports de sécurité.
- Connaissance du cadre ISO 27001 et des exigences réglementaires (ANJ, RGPD).
- Rédaction technique et restitution à des publics variés.
- Rigueur, confidentialité et travail en équipe dans un environnement grand compte.